

Document d'Architecture Technique (DAT)

Projet ISR-SRE4 / DAT

*Conception d'une architecture réseau sécurisée pour une
entreprise multi-sites*

Cartouche réglementaire

1. Identification du document

Titre du document : Document d'Architecture Technique (DAT) – Projet réseau multi-sites
ISR-SRE4

Référence documentaire : DAT-ISR-SRE4-v1.0

Version : v3.0

Statut du document : Brouillon

2. Classification

Niveau de confidentialité : Interne

3. Responsabilités

Auteur : Felicien Marie - Thomas Teixeira

Relecteur(s) : NA

Valideur(s) : NA

4. Référentiels applicables

RGPD

ISO/IEC 27001 et 27002

Guides ANSSI

Exigences ISR-SRE4

5. Historique des versions

Version 0.1 : 04/10/2025

Version 1.0 : 13/11/2025

Table des matières

1. Identification du document	2
2. Classification	2
3. Responsabilités	2
4. Référentiels applicables	2
5. Historique des versions	2
1. 1. Introduction	6
1.1 Cadrage de l'exercice	6
1.2. Hypothèses et limites	6
1.3. Introduction du DAT	6
2. Contexte & Contraintes	7
2.1. Organisation et répartition des sites	7
2.2. Infrastructures existantes	7
2.3. Contraintes techniques et fonctionnelles	8
3. Etudes de risque	9
3.1 Méthodologie	9
3.2 Matrice des risques	11
3.3 Risques identifiés	12
3.4 Synthèse	13
3.5 Mesures globales de réduction des risques	13
4. Conception du réseau	14
4.1 Objectif	14
4.2 Architecture logique	14
4.2.1 Vue d'ensemble	14
4.2.2 Découpage en zones logiques	16
4.2.3 Schéma logique	17
4.3 Segmentation réseau (VLANs)	19
4.4 Plan d'adressage IP	19
4.4.1 Principe de numérotation	20
4.4.2 Cartographie par site	20
A) Site 1 – Technique & Commercial + Hébergement (serveurs/DMZ)	21
B) Site 2 – Direction / Finance / RH	21
4.4.3 Adressage des accès distants & intersites	22
4.4.4 Réservations & conventions (exploitation)	22
4.4.5 Cohérence sécurité & filtrage (rappel)	22
4.5 Interconnexion des sites	22
4.5.1 Objectifs	23
4.5.2 Choix de la solution : VPN site-à-site IPsec	23
4.5.3 Architecture et intégration	24
4.5.4 Haute disponibilité et tolérance aux pannes	24
4.5.5 Sécurité et supervision	25
4.5.6 Synthèse	25

4.6 Accès des utilisateurs nomades	25
4.6.1 Objectifs	25
4.6.2 Choix de la solution : VPN distant sécurisé	26
4.6.3 Architecture et fonctionnement	26
4.6.4 Authentification et contrôle d'accès	27
4.6.5 Filtrage et sécurité réseau	28
4.6.6 Compatibilité et déploiement	28
4.6.7 Synthèse	29
4.7 Sécurisation LAN / WAN	29
4.7.1 Principes de sécurité retenus	29
4.7.2 Sécurisation du LAN	30
A) Segmentation logique	30
B) Filtrage inter-VLAN	30
C) Sécurisation des postes et switches	30
D) Sécurisation Wi-Fi	31
4.7.3 Sécurisation du WAN	32
A) Pare-feu périmétrique	32
B) Protection de la DMZ	32
C) VPN nomades	33
D) VPN site-à-site	33
4.7.4 Supervision et journalisation	34
4.7.5 Synthèse	34
5. Choix techniques	34
5.1 Technologie de routage	35
5.2 Pare-feu / Sécurité périmétrique	35
5.3 Technologie switching (LAN)	36
5.4 Technologie Wi-Fi	36
5.5 VPN site-à-site	36
5.6 VPN nomades	37
5.7 Serveur Web / DMZ	37
5.8 Technologies de supervision	38
5.9 Plan d'adressage privé RFC 1918	38
5.10 Résumé des choix techniques	39
6 – Schémad'architecture physique	40
7. Sécurisation physique	40
7.1 Protection des accès physiques	40
7.1.1 Contrôle d'accès par badge	40
7.1.2 Verrouillage des salles et procédures internes	41
7.1.3 Vidéosurveillance (caméras)	41
7.1.4 Contrôle d'accès renforcé : badge + empreinte digitale	41
7.2 Protection des équipements & continuité électrique	41
7.2.1 Onduleur (UPS)	42
7.3 Redondance matérielle & stockage	
7.3.1 Redondance matérielle (spare)	
7.3.2 Redondance de stockage	

7.4.1 Sauvegarde cloud sécurisée	42
7.4.2 Rétention, versionning et tests de restauration	42
8. Conclusion	43
9. Référence	44
10. Glossaire etacronymes	44
10.1 Termes généraux	44
10.2 Réseau & adressage	44
10.3 Sécurité réseau & VPN	45
10.4 Équipements & sécurité	46
10.5 Authentification & contrôle d'accès	46
10.6 Supervision & exploitation	46
10.7 Stockage, sauvegarde & disponibilité	47
10.8 Divers	47

1. 1. Introduction

1.1 Cadrage de l'exercice

Le projet consiste à produire un Dossier d'Architecture Technique (DAT) visant à concevoir une architecture réseau sécurisée pour une PME du secteur aéronautique. L'objectif est de proposer une solution complète, documentée et argumentée, intégrant une étude de risques, une architecture réseau segmentée, un plan d'adressage structuré et des préconisations de sécurité indépendantes de tout constructeur.

L'architecture devra notamment permettre la communication entre deux sites, l'accès nomade sécurisé, la mise en place de Wi-Fi séparés (collaborateurs / invités) et l'exposition d'un serveur Web en HTTPS.

1.2. Hypothèses et limites

Pour cadrer le périmètre du document, les hypothèses suivantes sont établies :

- Les serveurs existants sont déjà opérationnels.
- Les postes utilisateurs sont compatibles avec les protocoles VPN standards.
- Les locaux techniques permettent l'hébergement d'équipements réseau.
- La sécurité applicative, la haute disponibilité avancée, le PCA/PRA et le chiffrement financier ne sont pas inclus.
- Les solutions proposées doivent être génériques et non propriétaires.

1.3. Introduction du DAT

Le présent DAT décrit la démarche architecturale retenue pour concevoir un réseau sécurisé, segmenté et cohérent entre les deux sites.

Il présente successivement :

- l'étude de risques,
- l'architecture logique et le plan d'adressage,
 - les mécanismes d'interconnexion et de sécurité,
 - les choix techniques retenus,
 - ainsi qu'un schéma global de l'architecture.

Ce document constitue la référence technique pour la mise en œuvre de l'infrastructure réseau proposée.

2. Contexte & Contraintes

Cette partie présente le contexte réel de l'entreprise, distinct du cadrage de l'exercice. Elle décrit la structure organisationnelle, les infrastructures existantes et les contraintes techniques sur lesquelles repose l'architecture.

2.1. Organisation et répartition des sites

L'entreprise est une PME aéronautique répartie sur deux sites physiques hébergeant environ 100 utilisateurs, soit :

- Site 1 : Services Technique et Commercial
- Site 2 : Services Finance, Ressources Humaines et Direction

Chaque site dispose :

- d'une liaison Internet fibre optique 100 Mb/s symétrique,
- d'un local technique équipé d'une baie réseau,
- de l'arrivée opérateur permettant la collecte Internet.

2.2. Infrastructures existantes

Le site 1 centralise les principaux services informatiques, à savoir :

- un serveur de fichiers,
- un serveur de messagerie,
- un serveur de base de données,
- un serveur Web, destiné à être accessible en HTTPS depuis l'extérieur.

Le site 2 n'héberge pas de serveurs applicatifs métiers (fichier/mail/BDD/Web). En revanche, un serveur local (infrastructure) est présent sur chaque site pour assurer des services techniques et de continuité : par exemple relais DHCP/DNS cache, RADIUS pour 802.1X, collecte de journaux et supervision locale. Le site 2 reste donc un site utilisateur qui accède de manière sécurisée aux ressources hébergées au site numéro 1.

2.3. Contraintes techniques et fonctionnelles

L'architecture doit respecter les contraintes suivantes :

- Interopérabilité totale entre les deux sites, sans configuration spécifique sur les postes.
- Mise en place d'un accès nomade sécurisé pour les utilisateurs externes.
- Sécurisation des accès LAN sur les deux sites.
- Présence obligatoire de deux réseaux Wi-Fi distincts par site :
 - un Wi-Fi collaborateurs,
 - un Wi-Fi invité isolé du réseau interne.
- Le serveur Web doit être exposé en HTTPS, avec un accès contrôlé au serveur de base de données interne.
- Les solutions retenues doivent être :
 - indépendantes de tout constructeur spécifique,
 - économiquement cohérentes,
 - limitées au strict nécessaire, sans surdimensionnement.

3. Etudes de risque

L'étude de risques a pour objectif d'identifier, d'évaluer et de hiérarchiser les menaces susceptibles d'affecter la sécurité et la disponibilité du réseau de l'entreprise.

Elle permet de définir les mesures prioritaires à mettre en place pour réduire l'exposition aux menaces et renforcer la résilience de l'infrastructure.

3.1 Méthodologie

Limites de l'analyse :

L'analyse de risques présentée dans ce document est simplifiée et non exhaustive. Elle est réalisée exclusivement dans le cadre de l'exercice, afin d'illustrer la démarche d'identification et de hiérarchisation des risques et de justifier les choix d'architecture retenus.

L'analyse repose sur la combinaison de deux critères :

- La probabilité d'occurrence d'un événement indésirable ;
- La gravité de son impact sur le système d'information.

Chaque critère est noté sur une échelle de 1 à 5, permettant de calculer la criticité selon la formule : Criticité = Probabilité × Gravité

Échelle de probabilité (1 à 5)

Niveau	Description	Fréquence estimée / Interprétation	Exemple concret
1 – Très faible	L'événement est hautement improbable. Il peut survenir de manière exceptionnelle ou n'a jamais été observé	Moins d'une fois tous les 5 ans	Panne simultanée de deux routeurs redondants
2 – Faible	L'événement peut survenir rarement, mais reste plausible dans des conditions particulières.	Environ 1 fois tous les 2 à 3 ans	Erreur humaine isolée sur une configuration
3 – Moyenne	L'événement peut se produire occasionnellement au cours d'une année d'exploitation.	1 à 2 fois par an	Tentative d'accès non autorisé ou panne mineure

4 – Élevée	L'événement se produit régulièrement si aucune mesure n'est mise en place.	Plusieurs fois par an / par trimestre	Tentatives d'intrusion ou attaques externes observées
5 – Très élevée	L'événement est quasi certain ou récurrent sans protection spécifique.	Quotidien / continu	Scans de ports, phishing, trafic anormal permanent

Échelle de gravité (1 à 5)

Niveau	Description	Conséquences typiques	Exemple concret
1 – Faible	Impact négligeable sur le fonctionnement global. Aucune conséquence notable sur les services ou la sécurité.	Perturbation mineure, service rapidement rétabli	Redémarrage d'un poste client, micro coupure réseau sans effet utilisateur.
2 – Modérée	Impact localisé sur un service ou un petit groupe d'utilisateurs. L'activité peut se poursuivre avec gêne.	Panne partielle ou ralentissement temporaire.	Dysfonctionnement d'un switch d'étage, indisponibilité d'un partage réseau local.
3 – Significative	Perturbation notable d'un ou plusieurs services critiques. Impacts ressentis par une partie importante des utilisateurs..	Perte temporaire de productivité, interruption de service modérée.	Indisponibilité du serveur mail ou du Wi-Fi collaborateur pendant plusieurs heures.
4 – Sévère	Interruption majeure des services essentiels ou atteinte à la sécurité des données. L'activité est fortement dégradée.	Perte ou altération de données, arrêt de production, atteinte à la confidentialité.	Compromission du serveur web ou de la base de données interne.
5 – Critique	Impact global sur l'entreprise : arrêt complet des services, perte de données sensibles, ou atteinte grave à la réputation.	Arrêt total de l'activité, pertes financières, atteinte à la conformité.	Cyberattaque réussie, destruction de données critiques, exfiltration d'informations confidentielles.

3.2 Matrice des risques

PROBABILITE	5					
	4	Significatif			Innacceptable	
	3	Limité		Significatif		
	2	Négligeable		Limité		
	1					
		1	2	3	4	5
		GRAVITE				

- Négligeable
- Limité
- Significatif
- Inacceptable

3.3 Risques identifiés

N°	Menace identifiée	Impact potentiel	Probabilité	Gravité	Criticité	Mesures associées
1	Attaque externe sur le serveur Web (DDoS, intrusion)	Interruption de service, compromission de données Accès non autorisé au LAN	4	5		Mise en place d'un pare-feu, DMZ, filtrage HTTPS, WAF Authentification
2	Compromission du Wi-Fi collaborateur	autorisé au LAN	3	4		WPA2/WPA3-Enterprise, segmentation VLAN Isolation complète,
3	Mauvaise isolation du Wi-Fi invité	Fuite de données internes	3	3		accès Internet uniquement via NAT Sauvegarde des configurations,
4	Panne d'un routeur ou d'un lien Internet	Perte de connectivité inter-sites	2	4		redondance des équipements critiques Procédures de
5	Erreur de configuration réseau	Perturbation du trafic interne	3	3		modification, validation par pair, documentation VPN IPsec avec MFA, restriction
6	Accès non autorisé depuis l'extérieur	Fuite ou altération de données sensibles	2	5		des accès distants
7	Absence de mises à jour de sécurité	Vulnérabilités exploitables	4	3		Gestion régulière des correctifs et firmwares

3.4 Synthèse

L'analyse fait apparaître trois risques critiques nécessitant une attention prioritaire :

1. Les attaques externes sur le serveur Web exposé.
2. La compromission potentielle du Wi-Fi collaborateur.
3. Les accès distants non sécurisés.

Les risques moyens concernent principalement :

- la mauvaise isolation du réseau invité,
- les erreurs de configuration,
- et les pannes matérielles ponctuelles.

3.5 Mesures globales de réduction des risques

Les actions correctives et préventives s'articulent autour de trois axes :

Prévention :

- Mises à jour régulières des systèmes et équipements réseau.
- Sensibilisation des utilisateurs aux risques de sécurité (phishing, mots de passe).
- Utilisation de politiques d'accès fortes et authentification multifactorielle (MFA).

Protection :

- Segmentation stricte du réseau (VLANs).
- Isolation complète du Wi-Fi invité.
- Mise en place d'un VPN sécurisé pour les connexions distantes.
- Filtrage et inspection du trafic par pare-feu et WAF.

Surveillance :

- Journalisation des accès et tentatives d'intrusion.
- Sauvegarde régulière des configurations.
- Contrôle périodique des règles de filtrage et des accès.

4. Conception du réseau

4.1 Objectif

L'objectif de cette partie est de définir une architecture réseau sécurisée, claire et évolutive, répondant aux besoins opérationnels de l'entreprise.

Elle doit garantir :

- la communication entre les deux sites, sans intervention sur les postes clients,
- la sécurisation des accès internes (LAN filaires et Wi-Fi),
- la connexion à distance sécurisée des utilisateurs nomades,
- et l'exposition maîtrisée du serveur Web vers Internet.

4.2 Architecture logique

4.2.1 Vue d'ensemble

L'architecture cible repose sur une segmentation logique du réseau en zones de sécurité, interconnectées via un pare-feu central sur chaque site.

Cette segmentation a pour objectif d'isoler les flux métiers, de limiter les mouvements latéraux en cas d'incident et de contrôler précisément les communications entre les différentes parties du système d'information.

Les deux sites sont reliés au moyen d'un VPN site-à-site IPsec établi entre les pare-feux, ce qui garantit la confidentialité et l'intégrité des échanges intersites.

Les utilisateurs nomades accèdent aux ressources internes via un VPN distant sécurisé, dont les flux sont filtrés et limités selon le profil de l'utilisateur.

4.2.2 Découpage en zones logiques

L'architecture logique distingue les zones suivantes :

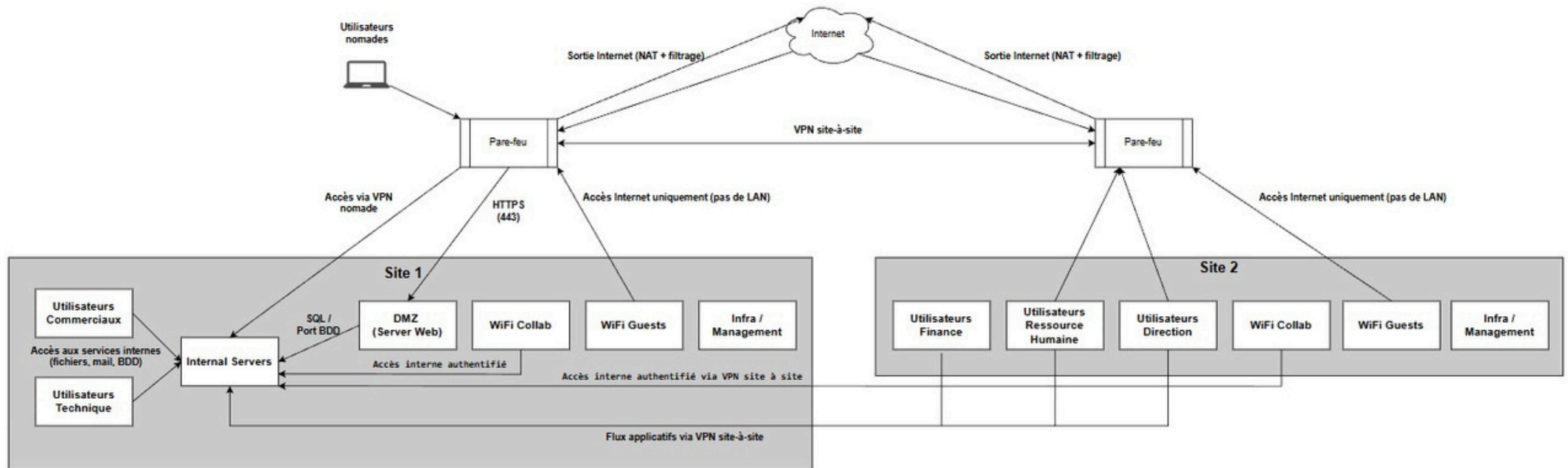
- Zone Utilisateurs métiers
Regroupe les postes des services Techniques, Production et Commerciaux.
Ces utilisateurs accèdent aux services internes nécessaires (messagerie, fichiers, applications métiers) sans visibilité directe sur les zones sensibles.

- Zone Données sensibles (Finance, RH, Direction)
Regroupe les postes manipulant des informations à forte criticité (données financières, données personnelles, informations de direction).
L'accès à ces postes est strictement limité aux utilisateurs autorisés et les flux en sortie sont fortement contrôlés.
- Serveur(s) local(aux) d'infrastructure (site 2) :
services techniques (ex : RADIUS 802.1X, DNS cache, collecte logs / supervision).
- Serveurs applicatifs métiers (fichier / mail / BDD / Web) :
hébergés au site 1.
- Zone Wi-Fi collaborateurs
Permet aux collaborateurs d'accéder au système d'information en mobilité.
Les accès sont authentifiés et les flux sont filtrés de la même manière que pour les postes filaires.
- Zone Wi-Fi invités
Fournit un accès Internet aux visiteurs, prestataires et intervenants externes.
Cette zone est totalement isolée des réseaux internes et ne permet aucun accès aux serveurs ou aux postes de l'entreprise.
- Zone Infrastructure et supervision
Regroupe les interfaces d'administration des équipements réseau (pare-feux, commutateurs, bornes Wi-Fi) ainsi que les systèmes de supervision et de journalisation.
Cette zone est accessible uniquement aux administrateurs.
- Zone VPN nomades
Regroupe les adresses IP attribuées aux utilisateurs distants se connectant via le VPN.
Les flux issus de cette zone sont filtrés de manière similaire à ceux des postes internes, avec des restrictions adaptées au rôle de l'utilisateur.
- Zone VPN intersites
Correspond au tunnel IPsec reliant les deux sites.
Les flux autorisés dans cette zone sont limités aux sous-réseaux internes des deux sites, de façon transparente pour les utilisateurs.

4.2.3 Schéma logique

Le schéma ci-dessous représente l'architecture logique du système d'information.

Il met en évidence la segmentation des réseaux (utilisateurs, serveurs, DMZ, Wi-Fi, administration), la répartition sur les deux sites, ainsi que les principaux flux autorisés.



4.3 Segmentation réseau (VLANs)

La segmentation réseau est conçue pour isoler les flux par service métier, limiter la propagation d'incidents et appliquer des politiques de sécurité différenciées selon le niveau de sensibilité des données manipulées.

Cette organisation respecte :

- le modèle de défense en profondeur (ISO 27002),
- le principe de cloisonnement logique recommandé par l'ANSSI.
- et les obligations de protection des données RH et financières selon la RGPD.

Table de segmentation réseau

VLAN	Nom / Usage	Description Postes et	Niveau de sensibilité
10	Technique / Production	équipements des équipes techniques (maintenance, production, support)	Moyen
20	Commercial	Postes du service commercial et marketing, accès restreint aux serveurs internes	Moyen
30	Finance	Postes du service comptabilité et gestion, accès aux outils financiers	Moyen
40	Ressources Humaines (RH)	Postes RH manipulant des données personnelles (salaires, dossiers employés)	Élevé
50	Direction	Postes de la Direction générale, accès limité et hautement sécurisé	Critique
60	Serveurs internes	Serveurs de fichiers, messagerie et base de données (hébergés sur le site 1)	Élevé
70	DMZ	Serveur Web exposé (accès HTTPS externe, accès BDD restreint)	Élevé
80	Wi-Fi Collaborateurs	Accès sans fil interne authentifié (WPA2/WPA3-Enterprise), accès restreint	Moyen
90	Wi-Fi Invité	Accès Internet uniquement via NAT, aucune communication interne	Moyen
100	Infrastructure réseau	Équipements de gestion : switchs, bornes Wi-Fi, pare-feux, serveurs d'administration	Critique
110	VPN Nomades	Pool IP des utilisateurs distants connectés via VPN	Moyen
120	VPN Site-à-Site	Liaison IPsec entre les deux sites	Critique

4.4 Plan d'adressage IP

4.4.1 Principe de numérotation

- Espace privé RFC 1918 :
- Adressage par site :
 - Site 1 → préfixe 10.10.X.0/24
 - Site 2 → préfixe 10.20.X.0/24
- Adressage par fonction : le troisième octet correspond au numéro de VLAN (X = VLAN).

Ex. VLAN 30 (Finance) au Site 2 → 10.20.30.0/24.

- Masque uniforme : /24 pour l'ensemble des VLANs (simplicité de lecture, d'exploitation et de filtrage).
- Convention passerelles & pools :
 - Passerelle (GW):1
 - Plage statique (serveurs/équipements) :10 –49
 - DHCP (postes/terminaux) :50 –199
 - Réserves / futures extensions :200 –254

Cette structuration facilite le dépannage (lecture immédiate “site + fonction”), la rédaction des ACL/pare-feu, et l'inventaire IP.

4.4.2 Cartographie par site

A) Site 1 – Technique & Commercial + Hébergement (serveurs/DMZ)

VLAN	Usage	Sous-réseau	Gateway
10 20	Technique / Production	10.10.10.0/24	10.10.10.1
30 40	Commercial	10.10.20.0/24	10.10.20.1
	Finance (si postes présents au S1)	(optionnel au S1)	— —
	Ressources Humaines (si postes présents au S1)	(optionnel au S1)	
50	Direction (si postes présents au S1)	(optionnel au S1)	—
60	Serveurs internes (Fichiers, Mail, BDD)	10.10.60.0/24	10.10.60.1
70	DMZ (Serveur Web exposé)	10.10.70.0/24	10.10.70.1
80	Wi-Fi Collaborateurs	10.10.80.0/24	10.10.80.1
90	Wi-Fi Invités (Internet-only)	10.10.90.0/24	10.10.90.1
100	Infrastructure (équipements, mgmt)	10.10.100.0/24	10.10.100.1

Remarques :

- Les serveurs internes et la DMZ sont exclusivement au Site 1 conformément au contexte.
- Les VLAN 30/40/50 au Site 1 sont des adressages réservées en cas de besoin de replis des services concernées

B) Site 2 – Direction / Finance / RH

VLAN	Usage	Sous-réseau	Gateway
10 20	Technique / Production (si besoin au S2)	(optionnel au S2)	— —
30 40	Commercial (si besoin au S2)	(optionnel au S2)	10.20.30.1
50	Finance	10.20.30.0/24	10.20.40.1
	Ressources Humaines (RH)	10.20.40.0/24	10.20.50.1
	Direction	10.20.50.0/24	
60	Serveurs internes	(non hébergés au S2)	— —
70	DMZ (Serveur Web exposé)	(non hébergés au S2)	10.20.80.1
80	Wi-Fi Collaborateurs	10.20.80.0/24	10.20.90.1
90	Wi-Fi Invités (Internet-only)	10.20.90.0/24	10.20.100.1
100	Infrastructure (équipements, mgmt)	10.20.100.0/24	

Remarques :

- Les données sensibles (RH, Finance, Direction) sont cloisonnées par VLAN dédié au Site 2.
- Les Wi-Fi sont séparés et alignés sur le même schéma que le Site 1 pour homogénéité.

4.4.3 Adressage des accès distants & intersites

Fonction	Sous-réseau	Commentaires
VPN Nomades	10.200.110.0/24	Pool d'attribution IP pour utilisateurs distants (MFA, accès restreint). Sous-espace distinct des LAN des 2 sites pour éviter tout chevauchement.
VPN Site-à-Site (IPsec)	10.200.120.0/30	Transit logique point-à-point du tunnel (si besoin d'une IP d'interface). Sinon, échange des routes des préfixes LAN uniquement.

Bonnes pratiques :

- Utiliser un **espace “hors sites”** pour les pools VPN (ex. 10.200.x.0/24) évite les collisions et simplifie les règles de filtrage.
- Les flux VPN S2S autorisent **uniquement** les préfixes utiles (ex. 10.10.0.0/16 ↔ 10.20.0.0/16).

4.4.4 Réservations & conventions (exploitation)

- .1 : passerelle par défaut du VLAN.
- .2 – .9 : adresses réservées aux équipements réseau critiques (pare-feu, L3, contrôleur Wi-Fi, etc.).
- .10 – .49 : hôtes statiques (serveurs, appliances).
- .50 – .199 : pool DHCP (postes, mobiles, imprimantes selon politique).
- .200 – .254 : réserves / extensions / équipements futurs.

Ces conventions uniformes réduisent les erreurs, accélèrent le troubleshooting et simplifient l'écriture des règles de sécurité (pare-feu/ACL).

4.4.5 Cohérence sécurité & filtrage (rappel)

Les VLAN RH / Finance / Direction ne communiquent pas directement avec les VLAN utilisateurs génériques (principe du moindre privilège).

La DMZ n'émet que vers la BDD (port(s) requis) et reçoit uniquement HTTPS depuis Internet.

Le Wi-Fi Invités est NAT-only Internet, sans routage vers les LAN internes.

Les VPN Nomades accèdent uniquement aux ressources nécessaires, selon rôle.

4.5 Interconnexion des sites

4.5.1 Objectifs

L'objectif de l'interconnexion est d'assurer une communication transparente, sécurisée et performante entre les deux sites de l'entreprise, sans qu'aucune configuration spécifique ne soit nécessaire sur les postes clients.

Les utilisateurs doivent pouvoir accéder aux ressources du site distant (serveurs, applications, fichiers) comme s'ils étaient sur le même réseau logique, tout en

maintenant un haut niveau de sécurité et une indépendance fonctionnelle en cas d'incident sur l'un des sites.

4.5.2 Choix de la solution : VPN site-à-site IPsec

L'interconnexion repose sur un tunnel VPN site-à-site IPsec, établi entre les pare-feux principaux des deux sites.

Ce tunnel permet de :

- chiffrer les communications entre les réseaux internes des deux sites,
- garantir l'intégrité et la confidentialité des données échangées,
- et assurer une interopérabilité totale avec des équipements réseaux de différents constructeurs (solution agnostique).

Technologies retenues

- Protocole : IPsec (Internet Protocol Security)
- Mode : Tunnel (Site-à-Site)
- Authentification : clé prépartagée (PSK) ou certificat X.509 selon le niveau d'exigence
- Chiffrement : AES-256 / SHA-256
- Échange de clés : IKEv2 (Internet Key Exchange version 2)
- Ports utilisés : UDP 500 (IKE) et UDP 4500 (NAT-T)

Ce choix garantit la compatibilité avec la plupart des pare-feux professionnels (Fortinet, Stormshield, pfSense, Cisco ASA, etc.) et respecte les recommandations de l'ANSSI en matière de tunnels chiffrés.

4.5.3 Architecture et intégration

Les pare-feux des deux sites établissent le tunnel VPN sur les liens fibre existants. Une fois le tunnel actif :

- le routage statique ou dynamique (OSPF, selon la solution retenue) permet la résolution automatique des sous-réseaux distants,
- les ACLs (Access Control Lists) limitent les flux aux seuls VLANs autorisés :
 - 10.10.0.0/16 ↔ 10.20.0.0/16,
 - exclusion des réseaux Wi-Fi invités (10.X.90.0/24),
 - autorisation spécifique pour les VLANs Serveurs et Direction.

Flux inter sites autorisés (exemples)

Origine	Destination	Ports / Services	Objectif
VLAN 10 (Tech) – Site 1	VLAN 60 (Serveurs) – Site 1	SMB / NFS	Accès fichiers internes
VLAN 30 (Finance) – Site 2	VLAN 60 (Serveurs) – Site 1	SQL / HTTPS	Accès base comptable / ERP
VLAN 50 (Direction) – Site 2	VLAN 60 (Serveurs) – Site 1	HTTPS / SSH	Supervision ou consultation
VLAN 100 (Infra) – Site 2	VLAN 100 (Infra) – Site 1	ICMP / SNMP / Syslog	Supervision réseau

Les flux sont limités à la stricte nécessité fonctionnelle, conformément au principe du moindre privilège.

4.5.4 Haute disponibilité et tolérance aux pannes

Même si la redondance de liens n'est pas explicitement demandée dans le sujet, l'architecture prévoit :

- la sauvegarde automatique de la configuration VPN,
- un redémarrage automatique du tunnel en cas de coupure temporaire,
- et la possibilité d'ajouter un second lien Internet ou VPN de secours sans modification majeure de la topologie.

Le pare-feu principal peut également assurer un basculement automatique (failover) vers un lien secondaire si l'entreprise choisit de renforcer la résilience à terme.

4.5.5 Sécurité et supervision

Mesures de sécurité appliquées au tunnel VPN :

- Chiffrement fort (AES-256) et intégrité (SHA-256) des paquets.
- Authentification mutuelle des pairs (PSK ou certificats). Limitation des flux autorisés par ACL. Renouvellement régulier des clés (périodicité
- IKE configurée à 24h). Journalisation complète des connexions, déconnexions et tentatives d'établissement.

Supervision :

groupe :teixei_t
3eme trimestre 2026

- Le tunnel VPN est surveillé via SNMP ou Syslog.
- Des alertes sont remontées en cas de perte de connectivité ou d'échec d'authentification.
- Les journaux VPN sont centralisés dans le VLAN 100 (Infrastructure).

4.5.6 Synthèse

Critère	Solution retenue
Type d'interconnexion	VPN site-à-site IPsec
Chiffrement	AES-256 / SHA-256
Authentification	PSK ou certificat
Échange de clés	IKEv2
Protocoles / Ports	UDP 500, UDP 4500
Flux autorisés	VLAN métiers / serveurs uniquement
Supervision	Syslog / SNMP / journalisation sur VLAN 100
Compatibilité	Multiconstructeur (solution agnostique)
Avantage principal	Sécurisation + transparence pour les utilisateurs

4.6 Accès des utilisateurs nomades

4.6.1 Objectifs

Les utilisateurs nomades (télétravail, déplacements professionnels, interventions sur sites externes) doivent pouvoir accéder de manière sécurisée, contrôlée et traçable aux ressources internes de l'entreprise.

L'accès distant doit offrir les mêmes fonctionnalités qu'en local, tout en appliquant des mécanismes de protection renforcés pour prévenir les risques liés à l'exposition Internet.

4.6.2 Choix de la solution : VPN distant sécurisé

L'accès nomade repose sur un VPN distant (Remote Access VPN) implémenté sur le pare-feu principal du Site 1, qui héberge l'ensemble des serveurs internes.

La solution retenue doit respecter les exigences suivantes :

- Chiffrement fort
- Authentification multi-facteur (MFA)
- Compatibilité multiconstructeur
- Aucune installation spécifique sur les postes clients si possible
- Aucune dépendance propriétaire

Protocole recommandé

- SSL VPN (OpenVPN / TLS 1.2+)
- IPsec IKEv2 Remote Access

Les deux protocoles sont compatibles avec les bonnes pratiques ANSSI.

Pourquoi IKEv2/SSL VPN ?

- Gestion native sur Windows, macOS, Linux et mobiles.
- Très bonne stabilité sur les réseaux fluctuants (4G/5G).
- Possibilité d'imposer du MFA.

4.6.3 Architecture et fonctionnement

Lorsqu'un utilisateur nomade se connecte :

1. Il s'authentifie via une interface sécurisée (client VPN ou portail SSL).
2. Le pare-feu lui attribue une adresse IP issue du VLAN 110 :
10.200.110.0/24
3. Les règles du pare-feu appliquent un filtrage strict basé sur son rôle.
4. Toutes les communications entre le client VPN et les serveurs internes sont chiffrées.

Localisation réseau du VPN distant

Le VPN nomade est isolé dans un VLAN dédié :

- VLAN 110 – 10.200.110.0/24
 - IPs dynamiques attribuées aux utilisateurs
 - Pas de routage vers les VLAN sensibles (RH, Finance, etc.) sauf autorisation explicite

4.6.4 Authentification et contrôle d'accès

Authentification multi-facteur (MFA)

Conformément aux normes ISO 27001/27002 et aux recommandations ANSSI :

- 1er facteur : login + mot de passe fort (complexité + renouvellement)
- 2e facteur :
 - Code OTP (Google Authenticator, Microsoft Authenticator, FreeOTP...)
 - OU Token matériel
 - Gestion des profils d'accès

Les droits sont attribués selon le rôle de l'utilisateur ("Role Based Access Control" – RBAC) :

Profil	Accès autorisés	Restrictions
Technicien / IT	Serveurs internes, supervision, outils techniques	Pas d'accès DMZ ↔ LAN direct
Commercial	Messagerie, fichiers partagés, applications métiers	Pas d'accès aux VLAN sensibles
RH / Finance	Applications RH/Finances situées dans le VLAN Serveurs	Accès limité aux ports applicatifs
Direction	Ensemble des services internes	Journalisation systématique

4.6.5 Filtrage et sécurité réseau

Les flux VPN nomades sont **filtrés par le pare-feu**, avant d'être autorisés vers les VLAN internes.

Flux autorisés (exemples)

Source	Destination	Port / Service	Motif
10.200.110.0/24	10.10.60.0/24 (Serveurs)	HTTPS/SMB/IMAP/ SMTP	Accès aux services internes
	10.10.70.0/24		Interdiction totale
10.200.110.0/24	(DMZ) 10.10.100.0/24	Aucun	
10.200.110.0/24	(Infra) Internet	 Selon profil	Outils d'admin (IT uniquement)
10.200.110.0/24		NAT	Navigation externe (facultative)

Mécanismes de sécurité complémentaires

- Renouvellement automatique des clés IKE toutes les 24h
- Déconnexion automatique après inactivité (timeout configurable)
- Détection de connexions anormales (IP suspecte, pays anormal)
- Limitation des connexions simultanées par utilisateur
- Journalisation complète dans le VLAN 100 (Infrastructure)

4.6.6 Compatibilité et déploiement

La solution VPN choisie est compatible avec :

- Windows 10/11,
- macOS,
- GNU/Linux,
- Android et iOS .

Le déploiement peut se faire :

- via un fichier de configuration,
- via le client VPN natif,
- ou via un portail SSL .

La solution est interopérable, donc agnostique vis-à-vis du constructeur du pare-feu.

4.6.7 Synthèse

La mise en place d'un VPN distant sécurisé permet :

- un accès fiable aux ressources internes depuis l'extérieur,
- un contrôle fin des permissions d'accès,
- une journalisation complète des activités distantes,
- une protection renforcée par MFA et chiffrement fort,
- et une conformité aux attentes ISO 27002, ANSSI, et RGPD.

L'architecture reste cohérente avec l'ensemble du réseau, sans créer de dépendances propriétaires, et répond strictement aux exigences du sujet.

4.7 Sécurisation LAN / WAN

La sécurité du réseau repose sur une approche défense en profondeur, appliquée à la fois au LAN interne et aux accès WAN exposés à Internet.

L'objectif est de garantir la confidentialité, l'intégrité et la disponibilité des communications tout en limitant la propagation d'incidents au sein de l'infrastructure.

4.7.1 Principes de sécurité retenus

La sécurisation du LAN et du WAN s'appuie sur les principes suivants :

- Segmentation stricte des réseaux (VLANs, DMZ, Wi-Fi isolés).
- Filtrage centralisé via un pare-feu de type « next-generation ».
- Contrôle des flux entrants/sortants basé sur le principe du moindre privilège.
- Authentification forte .
- Surveillance et journalisation dans un VLAN dédié (Infrastructure).
- Chiffrement systématique des flux traversant Internet.

Ces mesures sont conformes aux bonnes pratiques ANSSI et aux contrôles ISO/IEC 27002 relatifs à la sécurité réseau.

4.7.2 Sécurisation du LAN

A) Segmentation logique

Le LAN est segmenté en VLANs par service (RH, Finance, Direction, Technique, Commercial, etc.) afin :

- d'isoler les données sensibles,
- de limiter les mouvements latéraux en cas d'intrusion,
- et d'appliquer des politiques de filtrage ciblées.

Les VLAN sensibles (RH, Finance, Direction) sont isolés par défaut et accessibles uniquement via des règles explicites.

B) Filtrage inter-VLAN

Le pare-feu central applique des ACL permettant uniquement :

- les flux justifiés par les besoins métier,
- les flux contrôlés vers les serveurs internes (VLAN 60),
- l'interdiction des flux directs vers RH/Finance/Direction depuis les VLAN utilisateurs.

Exemple de règles appliquées :

Source	Destination	Action	Justification
VLAN 90 (Invités)	LAN interne	Deny	Isolation complète
VLAN 80 (Wi-Fi collab)	Serveurs	Allow (ports métiers)	Mobilité interne
RH / Finance / Direction	Autres VLANs	Deny	Données sensibles
Tous VLANs internes	DMZ	Deny sauf port BDD	Protection du LAN

C) Sécurisation des postes et switches

- Ports inutilisés désactivés.
- VLAN par défaut interdit (pas de VLAN 1).
- Storm control / BPDU Guard / DHCP Snooping / Dynamic ARP Inspection activés.
- Administration des switches via VLAN 100 (Infrastructure) uniquement.
- Accès administrateur protégé via SSH + certificats ou clé forte.

Ces mesures empêchent les attaques de type rogue DHCP, ARP spoofing, STP spoofing ou MAC flooding.

D) Sécurisation Wi-Fi

Wi-Fi collaborateurs :

- WPA2/WPA3-Enterprise
- Authentification via serveur RADIUS / AD
- Isolation client-to-client activée
- VLAN 80 dédié

Wi-Fi invités :

- SSID isolé → VLAN 90
- Accès Internet uniquement via NAT
- Aucun routage interne
- Filtrage DNS + blocage des ports sensibles

Filtrage MAC via RADIUS

En complément de WPA2/WPA3-Enterprise, le contrôleur Wi-Fi s'appuie sur un serveur RADIUS afin de vérifier l'adresse MAC des terminaux autorisés.

Cette mesure permet :

- de bloquer les terminaux non déclarés,
- de renforcer l'accès au Wi-Fi collaborateurs,
- de limiter les risques d'usurpation d'identité réseau.

Le filtrage MAC est géré directement au niveau du serveur RADIUS, ce qui centralise les contrôles d'accès et facilite l'audit.

4.7.3 Sécurisation du WAN

Le WAN désigne l'ensemble des communications entre :

- le LAN et Internet,
- la DMZ exposée,
- le VPN nomade,
- le VPN intersites.

A) Pare-feu périmétrique

Le pare-feu joue un rôle central dans la sécurisation WAN :

- Inspection stateful du trafic
- Filtrage des ports entrants (only HTTPS 443 vers DMZ)
- Désactivation système des services inutiles
- Protection contre attaques courantes :
 - scans de ports,
 - attaques par force brute,
 - injections protocolaires,
 - DoS basiques.

Les journaux WAN sont envoyés dans le VLAN 100 (Infra).

B) Protection de la DMZ

La DMZ héberge uniquement le **serveur Web exposé** (VLAN 70).

Règles de sécurité appliquées :

Flux	Action	Justification
Internet → DMZ	HTTP (80) redirigé vers HTTPS (443)	Navigation sécurisée
DMZ → Serveurs internes	SQL / port applicatif	Accès strict nécessaire
LAN interne → DMZ	Deny	Protection du LAN
DMZ → Internet	Allow (sortant limité)	MAJ & supervision

L'objectif est d'empêcher tout pivot entre DMZ → LAN.

C) VPN nomades

- Accès distant via SSL VPN ou IKEv2. Multi-factor
- authentication obligatoire. Attribution d'IP depuis le
- VLAN 110 (10.200.110.0/24). Filtrage spécifique par
- rôle (RBAC). Tous les flux VPN sont inspectés et
- journalisés.

D) VPN site-à-site

- Tunnel IPsec chiffré (AES-256, IKEv2).
- ACLs strictes entre les préfixes 10.10.0.0/16 ↔ 10.20.0.0/16.
- Exclusion explicite des VLAN 90 (Invités).
- Pas de routage des flux venant de la DMZ dans le tunnel.

4.7.4 Supervision et journalisation

Les équipements réseau et de sécurité remontent leurs logs vers un serveur ou équipement centralisé situé dans le VLAN 100 (Infrastructure) :

- Logs pare-feu (WAN, DMZ, VPN).
- Logs switches (port-security, spanning-tree, DHCP-snooping).
- Logs VPN nomades et site-à-site.

Objectifs :

- détecter les anomalies,
- retracer les actions en cas d'incident,
- faciliter l'audit de conformité.

IDS / IPS (détection et prévention d'intrusions)

Un système IDS/IPS open source (ex. Snort ou Suricata) est déployé afin d'analyser le trafic réseau en temps réel.

Il assure :

- la détection des tentatives d'intrusion (scans, injections, exploits),
- la prévention automatique de certaines attaques via des règles IPS,
- l'alerte en cas de comportements anormaux,
- l'envoi des journaux vers le serveur de supervision

4.7.5 Synthèse

La sécurisation LAN/WAN repose sur :

- une segmentation réseau stricte et conforme aux bonnes pratiques,
- un filtrage centralisé basé sur le principe du moindre privilège,
- la protection de la DMZ et des accès distants,
- une supervision continue des équipements et des flux.

L'ensemble garantit un niveau de sécurité adapté au contexte de l'entreprise et aux exigences réglementaires françaises et européennes (ANSSI, ISO 27002, RGPD).

5. Choix techniques

Cette section présente et justifie les principaux choix techniques retenus pour la conception du réseau.

Les solutions sélectionnées ont été choisies pour leur interopérabilité, leur simplicité d'administration, et leur conformité aux bonnes pratiques ANSSI / ISO 27002, tout en respectant le périmètre fonctionnel imposé dans l'exercice.

5.1 Technologie de routage

Le routage inter-VLAN et l'interconnexion des deux sites reposent sur un pare-feu / routeur central installé sur chaque site

Choix : Routage via pare-feu (L3 + ACL)

- Permet de centraliser le filtrage inter-VLAN.
- Cohérent avec une topologie comprenant une DMZ, plusieurs VLAN sensibles et une politique de sécurité stricte.
- Facile à maintenir : un seul endroit pour gérer les règles.
- Compatible avec toutes les architectures multi-VLAN.

5.2 Pare-feu / Sécurité périmétrique

Choix : Pare-feu de nouvelle génération (NGFW)

Fonctionnalités nécessaires :

- Inspection stateful
- NAT / PAT
- Filtrage L3/L4 / L7
- Support IPsec (site-à-site + nomades)
- Support SSL VPN
- Filtrage URL / DNS (optionnel)
- Journalisation centralisée

Ce choix est motivé par :

- la présence d'une DMZ,
- l'obligation de sécuriser l'accès distant,
- la gestion du VPN inter-sites.

Les solutions standard compatibles avec ce périmètre incluent :

Fortigate, Stormshield, pfSense+, OPNsense, Cisco Firepower, etc.

5.3 Technologie switching (LAN)

Choix : Commutateurs administrables niveau 2 / 3

Raisons du choix :

- Gestion des VLANs
- Support 802.1Q
- Sécurité avancée (port-security, DHCP snooping, DAI)
- Supervision (SNMP)
- Haute stabilité et compatibilité multi-constructeurs

À ce niveau, les commutateurs de niveau 2 suffisent pour le cœur LAN, le routage étant assuré par le pare-feu.

5.4 Technologie Wi-Fi

Choix : Wi-Fi d'entreprise centralisé

- Deux SSID distincts : Collaborateurs et Invités
- Authentification sécurisée WPA2/WPA3-Enterprise
- Gestion centralisée via contrôleur intégré ou cloud
- VLAN dédié pour chaque SSID
- Isolation client-to-client activée

5.5 VPN site-à-site

Choix : Tunnel IPsec IKEv2

Caractéristiques :

- Chiffrement AES-256
- Authentification forte (PSK ou certificat)
- Compatibilité multi-constructeurs
- Support natif sur pare-feux courants
- Fiabilité éprouvée et standard ouvert

5.6 VPN nomades

Choix : SSL VPN ou IPsec IKEv2 (selon OS)

Complété par :

- Authentification multifacteur (MFA)
- Attribution d'IP depuis un pool dédié (VLAN 110)
- Filtrage selon rôle (RBAC)

5.7 Serveur Web / DMZ

Choix : Serveur Web isolé dans une DMZ dédiée

- Hébergé sur le Site 1, VLAN 70
- Accessible uniquement en HTTPS
- Port 443 ouvert depuis Internet
- Communication serveur Web → BDD limitée au port applicatif
- Journalisation dans le VLAN 100

5.8 Technologies de supervision

Choix : Supervision centralisée (SNMP + Syslog)

- Collecte des logs pare-feu
- Collecte des événements des switches
- Suivi du tunnel IPsec
- Journalisation des accès VPN
- Alertes automatiques en cas d'incident

5.9 Plan d'adressage privé RFC 1918

Choix : Plage privée 10.X.0.0/16

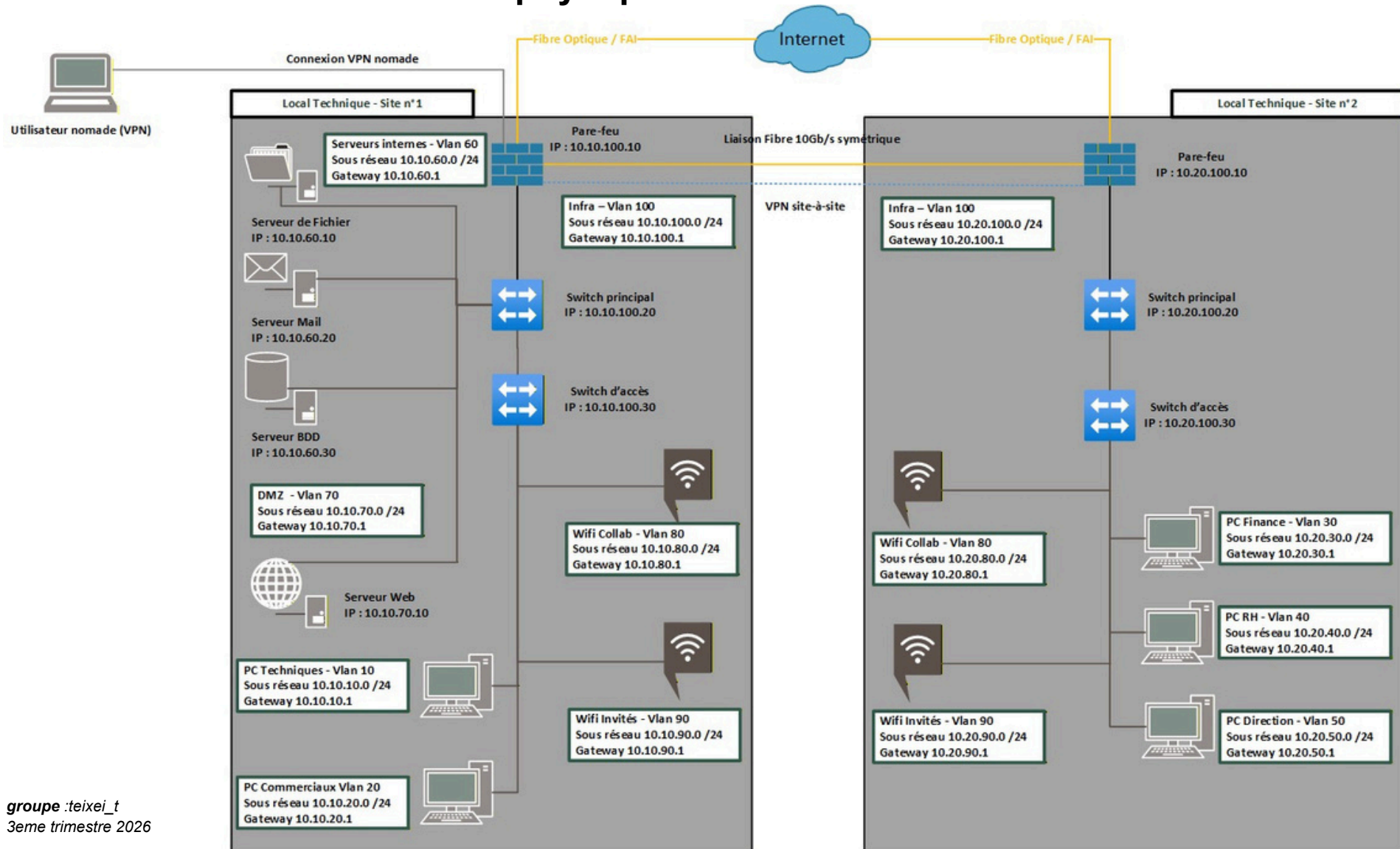
Raisons :

- Flexibilité
- Cohérence par site (10.10.X.X et 10.20.X.X)
- Aucune dépendance à un fournisseur
- Aligné sur les recommandations de l'exercice

5.10 Résumé des choix techniques

Domaine	Choix retenu
Routage	Centralisé sur pare-feu
Pare-feu	NGFW compatible IPsec/SSL
Switching	Switchs L2 administrables
Wi-Fi	WPA2/WPA3-Enterprise + VLANs
Interconnexion	VPN IPsec IKEv2
VPN nomades	SSL VPN / IKEv2 + MFA
DMZ	Serveur Web isolé (HTTPS only)
Supervision	SNMP + Syslog
Adressage	RFC1918, 10.10.X / 10.20.X

6 – Schéma d'architecture physique



7. Sécurisation physique

La sécurisation physique des infrastructures réseau constitue un élément essentiel de la disponibilité et de l'intégrité du système d'information.

Les équipements critiques (pare-feux, switchs, serveurs, baies de brassage) sont regroupés dans des locaux techniques dédiés sur chacun des deux sites.

Les mesures suivantes sont mises en place pour limiter les risques d'intrusion physique, de manipulation non autorisée ou d'interruption de service.

7.1 Protection des accès physiques

7.1.1 Contrôle d'accès par badge

Les locaux techniques des deux sites sont protégés par un système de contrôle d'accès par badge.

Cette mesure permet :

- de limiter l'accès aux seules personnes habilitées (équipe informatique, direction technique) ;
- d'assurer la traçabilité des entrées et sorties via un journal horodaté ;
- d'éviter toute intrusion ou manipulation non autorisée.

Les droits d'accès sont révisés régulièrement afin de garantir une sécurité adaptée aux besoins du SI.

7.1.2 Verrouillage des salles et procédures internes

Les salles techniques sont systématiquement fermées à clé.

Une procédure interne définit :

- les personnes autorisées à pénétrer dans les locaux ;
- les conditions d'intervention (horaires, supervision, enregistrement) ;
- l'obligation de refermer et sécuriser les accès après chaque opération.

7.1.3 Vidéosurveillance (caméras)

Objectif : dissuasion + preuve + détection.

Mesure : mise en place d'un système de vidéosurveillance couvrant :

- accès aux locaux techniques (portes, couloirs immédiats),
- zones de baie réseau/serveurs (angle large + point focal si besoin),
- zones d'arrivée opérateur (si accessible).

Exploitation / règles :

- enregistrement horodaté, accès restreint (IT / direction),
- conservation limitée (ex : 15 à 30 jours, selon politique interne),
- alertes possibles en cas d'accès hors horaires / détection de mouvement,
- affichage et conformité RGPD (information des personnes + finalité sécurité)

7.1.4 Renforcement du contrôle d'accès : badge + empreinte digitale (2FA physique)

Principe : contrôle d'accès "fort" sur les zones les plus sensibles.

Mesure :

Badge obligatoire pour tous les accès (déjà en place),

Empreinte digitale en second facteur uniquement pour :

- la salle serveurs/baie principale,
- la zone DMZ/équipements périmétriques si séparée, ou toute zone où sont stockées des données sensibles (ex : sauvegardes).

Bénéfices :

- réduit le risque de badge prêté/volé,
- améliore la traçabilité (badge + biométrie = preuve forte),
- limite l'accès aux seuls personnels habilités (principe du moindre privilège).

Bonnes pratiques :

- liste blanche des personnes autorisées + revue périodique des droits,
- procédure immédiate de révocation en cas de perte de badge,
- mode "dégradé" documenté (panne lecteur biométrique → accès supervisé).

7.1.5 Gestion des visiteurs et prestataires (simple mais efficace)

- accès accompagné obligatoire (jamais seul dans le local),
- badge "visiteur" temporaire (droits limités + durée limitée),
- registre d'entrée/sortie + motif d'intervention,
- interdiction des photos / branchements non validés. DAT_v1.1.pdf

7.2 Protection des équipements & continuité électrique

7.2.1 Onduleur (UPS)

Les équipements essentiels sont alimentés via un onduleur (UPS) assurant :

- la continuité électrique en cas de coupure ;
- la protection contre les microcoupures et surtensions ;
- un arrêt propre et sécurisé des serveurs en cas d'interruption prolongée.

Cela évite la corruption des données et les interruptions non maîtrisées.

7.3 Redondance matérielle & stockage

7.3.1 Redondance matérielle (spare)

Pour réduire les temps d'interruption en cas de panne, l'entreprise maintient un stock de matériel de rechange :

- switch d'accès de secours ;
- point d'accès Wi-Fi supplémentaire ;
- modules SFP et câbles RJ45 pré-certifiés ;
- blocs d'alimentation compatibles.

Les configurations des équipements réseau sont régulièrement sauvegardées, permettant une remise en service rapide d'un spare.

7.3.2 Redondance de stockage

Les serveurs internes du Site 1 utilisent une redondance de stockage basée sur des niveaux de RAID adaptés :

- RAID 5 pour le serveur de fichiers ;
- RAID 1 pour le serveur de messagerie ;
- RAID 5 pour le serveur de base de données.

7.4 Sauvegarde externalisée

7.4.1 Sauvegarde cloud sécurisée

Les données critiques (fichiers, messagerie, BDD) sont sauvegardées vers un stockage cloud sécurisé :

- chiffrement AES-256 avant envoi ;
- transfert via un canal TLS ;
- stockage isolé du réseau interne.

Cette solution protège contre les pertes majeures (incendie, vol, corruption de données).

7.4.2 Rétention, versionning et tests de restauration

Un système de rétention multicouches permet de conserver plusieurs versions des données afin de se prémunir contre :

- les suppressions accidentelles ;
- les corruptions logicielles ;
- les attaques par ransomware.

Des tests de restauration sont réalisés régulièrement pour garantir la fiabilité des sauvegardes et la maîtrise de la procédure de reprise.

8. Conclusion

Le Document d'Architecture Technique présenté ci-dessus répond au besoin d'une entreprise répartie sur deux sites et souhaitant sécuriser son infrastructure réseau. L'objectif était de proposer une architecture claire, cohérente et adaptée au contexte tout en respectant les consignes du sujet.

La solution retenue s'appuie sur une segmentation du réseau en VLANs, l'isolation des services sensibles, la mise en place d'une DMZ pour le serveur Web, ainsi que la séparation des accès Wi-Fi collaborateurs et invités.

Les deux sites sont interconnectés via un VPN IPsec, et les utilisateurs nomades disposent d'un accès distant sécurisé.

L'ensemble proposé reste réaliste pour une PME tout en intégrant les bonnes pratiques essentielles : filtrage, cloisonnement, protection physique, sauvegardes et redondance minimale.

Cette approche permet de garantir un niveau de sécurité satisfaisant, une administration plus simple et une continuité de service adaptée aux besoins de l'entreprise.

Ce document constitue donc une base solide pour le déploiement de l'infrastructure réseau décrite dans l'énoncé.

9. Référence

- Règlement général sur la protection des données (RGPD)
- Normes ISO/IEC 27001 et 27002 (gestion de la sécurité de l'information et bonnes pratiques de sécurité)
- Guides de l'ANSSI relatifs à l'hygiène informatique et à la sécurité des réseaux
- Exigences pédagogiques et consignes du module ISR-RES4

Règlement général sur la protection des données (RGPD)

Normes ISO/IEC 27001 et 27002 (gestion de la sécurité de l'information et bonnes pratiques de sécurité)

Guides de l'ANSSI relatifs à l'hygiène informatique et à la sécurité des réseaux

Exigences pédagogiques et consignes du module ISR-RES4

10. Glossaire et acronymes

Cette section rassemble les principaux termes et acronymes utilisés dans ce document. Les définitions sont volontairement simplifiées et adaptées au contexte du projet pédagogique ISR-RES4.

10.1 Termes généraux

DAT (Document d'Architecture Technique)

Document qui décrit la conception détaillée d'une solution technique. Ici : l'architecture réseau sécurisée proposée pour l'entreprise fictive du sujet.

SI (Système d'Information)

Ensemble des équipements, logiciels, réseaux et données utilisés par l'entreprise pour fonctionner au quotidien.

RGPD (Règlement Général sur la Protection des Données)

Règlement européen qui encadre la collecte, le traitement et la protection des données personnelles.

ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information)

Agence française qui publie des recommandations et guides sur la sécurité des systèmes d'information.

10.2 Réseau & adressage

LAN (Local Area Network) Réseau local interne à un site (bureaux, bâtiment, étage).

WAN (Wide Area Network)

Réseau étendu reliant plusieurs sites entre eux ou à Internet.

VLAN (Virtual Local Area Network)

Réseau logique créé sur un même réseau physique pour segmenter et isoler différents types de flux (RH, Finance, invités, etc.).

DMZ (Demilitarized Zone)

Zone réseau isolée qui héberge les services exposés sur Internet (ex : serveur Web), tout en protégeant le reste du LAN.

SSID (Service Set Identifier)

Nom d'un réseau Wi-Fi visible dans la liste des réseaux sans fil.

NAT (Network Address Translation)

Mécanisme qui permet à des machines internes avec des adresses IP privées d'accéder à Internet en passant par une adresse IP publique.

RFC 1918

Document qui définit les plages d'adresses IP privées utilisables dans les réseaux internes

10.3 Sécurité réseau & VPN

VPN (Virtual Private Network)

Tunnel chiffré qui permet à un site ou un utilisateur distant de se connecter de manière sécurisée au réseau de l'entreprise.

VPN site-à-site

VPN établi entre deux équipements réseau (souvent des pare-feux) pour relier les réseaux locaux de deux sites distants.

VPN nomade / VPN distant

VPN utilisé par un utilisateur (PC portable, smartphone) pour accéder au réseau interne depuis l'extérieur.

IPsec (Internet Protocol Security)

Ensemble de protocoles qui permet de chiffrer et authentifier les communications IP. Utilisé pour sécuriser les VPN.

IKEv2 (Internet Key Exchange version 2)

Protocole utilisé avec IPsec pour négocier et renouveler les clés de chiffrement.

SSL / TLS (Secure Sockets Layer / Transport Layer Security)

Protocoles qui sécurisent les communications (ex : HTTPS, certains VPN).

HTTPS (HyperText Transfer Protocol Secure)

Version sécurisée de HTTP, utilisée pour l'accès Web chiffré (port 443).

10.4 Équipements & sécurité

Pare-feu / Firewall

Équipement (ou logiciel) qui filtre le trafic réseau selon des règles définies (ports, adresses IP, protocoles).

NGFW (Next Generation Firewall)

Pare-feu de « nouvelle génération » qui ajoute des fonctions avancées (filtrage applicatif, VPN, journalisation, etc.).

ACL (Access Control List)

Liste de règles qui définissent quels flux réseau sont autorisés ou interdits entre différentes zones.

WPA2 / WPA3-Enterprise

Normes de sécurité pour les réseaux Wi-Fi d'entreprise, avec authentification renforcée.

10.5 Authentification & contrôle d'accès

MFA (Multi-Factor Authentication)

Authentification multi-facteur : l'utilisateur doit prouver son identité avec au moins deux éléments (mot de passe + code à usage unique, par exemple).

RBAC (Role-Based Access Control)

Contrôle d'accès basé sur les rôles : les droits sont définis en fonction du profil de l'utilisateur (technique, commercial, RH, etc.).

Principe du moindre privilège

Principe qui consiste à n'accorder à un utilisateur que les droits strictement nécessaires à son travail.

10.6 Supervision & exploitation

SNMP (Simple Network Management Protocol)

Protocole utilisé pour superviser et remonter des informations sur l'état des équipements réseau.

Syslog

Standard de journalisation permettant aux équipements réseau d'envoyer leurs logs vers un serveur central.

Journalisation / Logs

Enregistrement des événements importants (connexions, erreurs, alertes) pour faciliter le diagnostic et l'analyse en cas d'incident.

10.7 Stockage, sauvegarde & disponibilité

RAID (Redundant Array of Independent Disks)

Technique qui permet d'utiliser plusieurs disques durs comme un ensemble redondant pour améliorer les performances et/ou la tolérance aux pannes.

Hot spare

Disque de secours intégré à une grappe RAID, prêt à prendre automatiquement le relais en cas de défaillance d'un disque.

UPS / Onduleur (Uninterruptible Power Supply)

Équipement qui fournit une alimentation de secours en cas de coupure et protège contre les microcoupures.

Sauvegarde externalisée / sauvegarde cloud

Sauvegarde des données vers un environnement distant (cloud) pour pouvoir les restaurer en cas de sinistre sur site.

10.8 Divers

BDD (Base de Données)

Système qui stocke et organise les données applicatives (ex : données métier utilisées par le serveur Web).

SMB / NFS

Protocoles de partage de fichiers sur le réseau (SMB surtout en environnement Windows, NFS plutôt en environnement Linux/Unix).